SECURE DATA SERVICE
enabling the research community

Human Security in Protecting Confidentiality of Data

REZA AFKHAMI

Senior Data and Support Service Officer

UK Data Archive

Funding provided by:

E·S·R·C ECONOMIC & SOCIAL RESEARCH COUNCIL

Service delivered by:

UK • DATA ARCHIVE

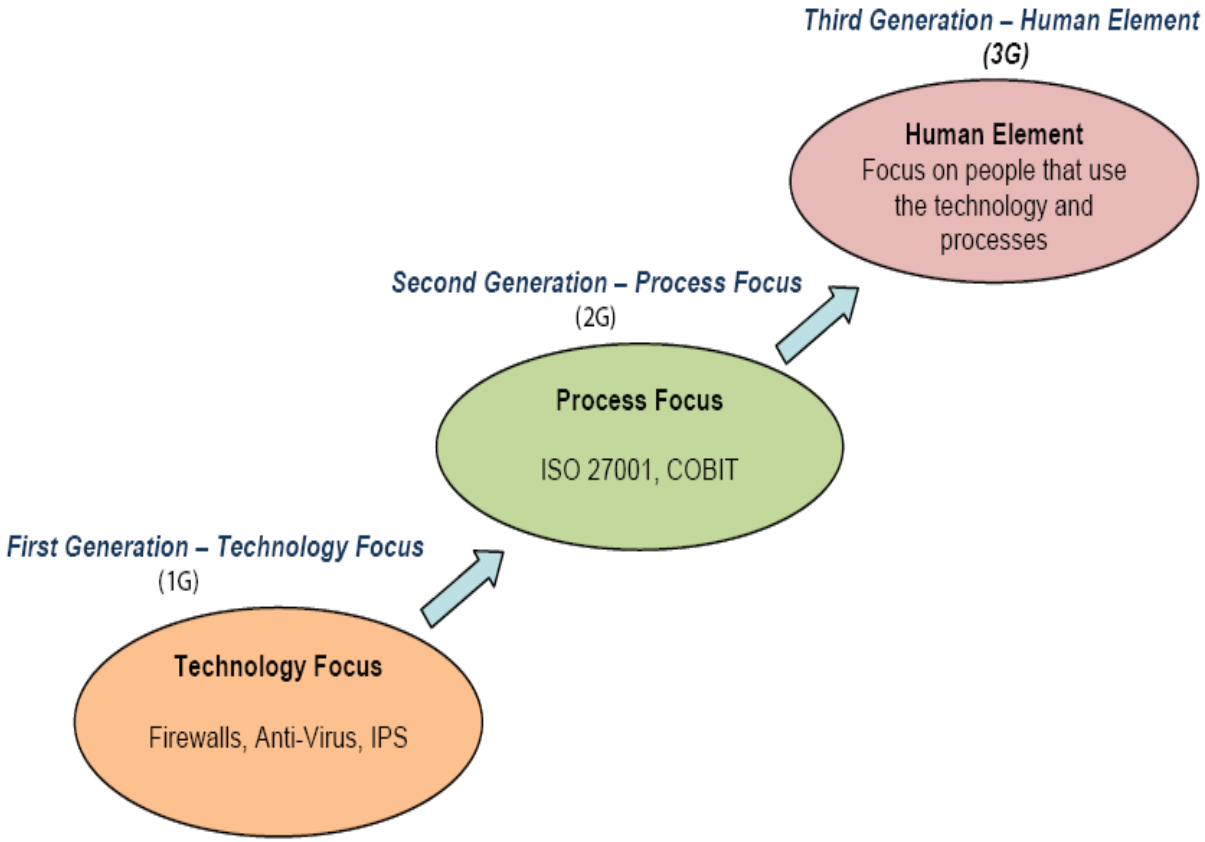
Outline

- Evolution of information Security
- Human vulnerabilities
- Social Engineering
- Security Tradeoffs
- Core Approach to Human Information Security
- Solutions and Countermeasures
- Concluding Remarks

Evolution of information Security

- Human is the weakest link
  - Reason
  - Catalyst
- Human Error
- Human Fraud
- Challenges
  - How do people think and feel about information security?
  - How to raise users' base level of awareness in an effective and meaningful way without creating an environment of paranoia?

Evolution of Information Security



Human Vulnerabilities1

- Social engineering attacks
- Passwords
- Ability overestimation
  - Lie detector bias
  - Optimism bias
  - Fixed-action –patterns
  - Truth bias
  - Third person effect

Human Vulnerabilities 2

- Humans influenced by
  - Authority
  - Scarcity
  - Liking and similarity
  - Reciprocation
  - Commitment and consistency
  - Social proof
  - Surprise
  - Overload
  - Rapport

  - *(Cialdini, 2003)*

Human Vulnerabilities 3

- What is deception?
- Types of deception
  - Dissimulation
    - Masking information
    - Repackaging information
    - Surprise
  - Simulation
    - False information
    - Mimicking
    - Decoying
  - *(Bowyer, 2003)*

What is social engineering?

“Social engineering is the art of manipulating people into performing actions or divulging confidential information”

(Kevin Mitinic, 1995)

Why does it work?

- Humans
  - We are emotionally weak and like to help
  - We easily succumb to pressure
  - We cant correctly judge if someone is lying – bias towards truth and stereotypical thinking
- Current defense mechanisms
  - Security policies – single loop
  - Employee training
- Security policies
  - Has humans involved in creation
  - Are not updated
  - Are not followed

A Social Engineering Scenario

Spot social engineering techniques

(Levine, 2003)

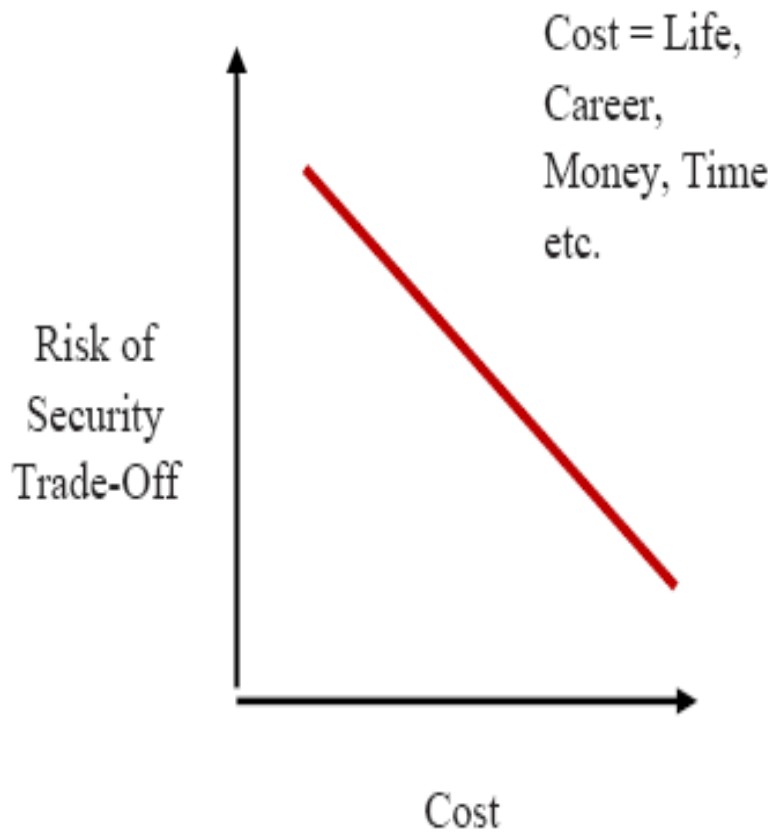
Human and Password Authentication

- User overload of information
- Human memory limitations
  - Weak passwords
  - Common passwords
  - Multiple passwords
  - Multiple systems
  - Visible passwords
- Security policies neglected

Security tradeoffs

- Reasons
  - Convenience
  - Cost
  - Self preservation
  - Ignorance
  - Perception/feeling
  - Fear
  - Culture

Security Tradeoffs



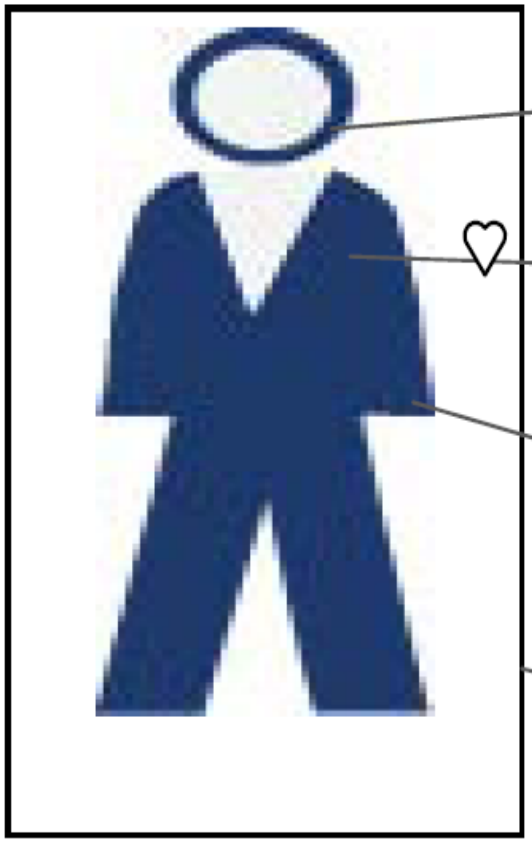
Conscious Competence Model

Knowledge Level	Awareness Levels	
	Unconscious	Conscious
Incompetence	**Quadrant 1** You don't know that you do not know.	**Quadrant 2** You know that you do not know.
Competence	**Quadrant 3** You can do it without thinking about it.	**Quadrant 4** You can do it if you think about it.

Strategies for Increasing Information Security Competence

- Step 1: Set Goals
- Step 2: Increase Security Perception by conveying Concepts
- Step 3: Increase Security Acceptance
- Step 4: Applying Security Skills
- Step 5: Linking Security with the organizations Goals
- Step 6: Continuous Measurement

Human Information security



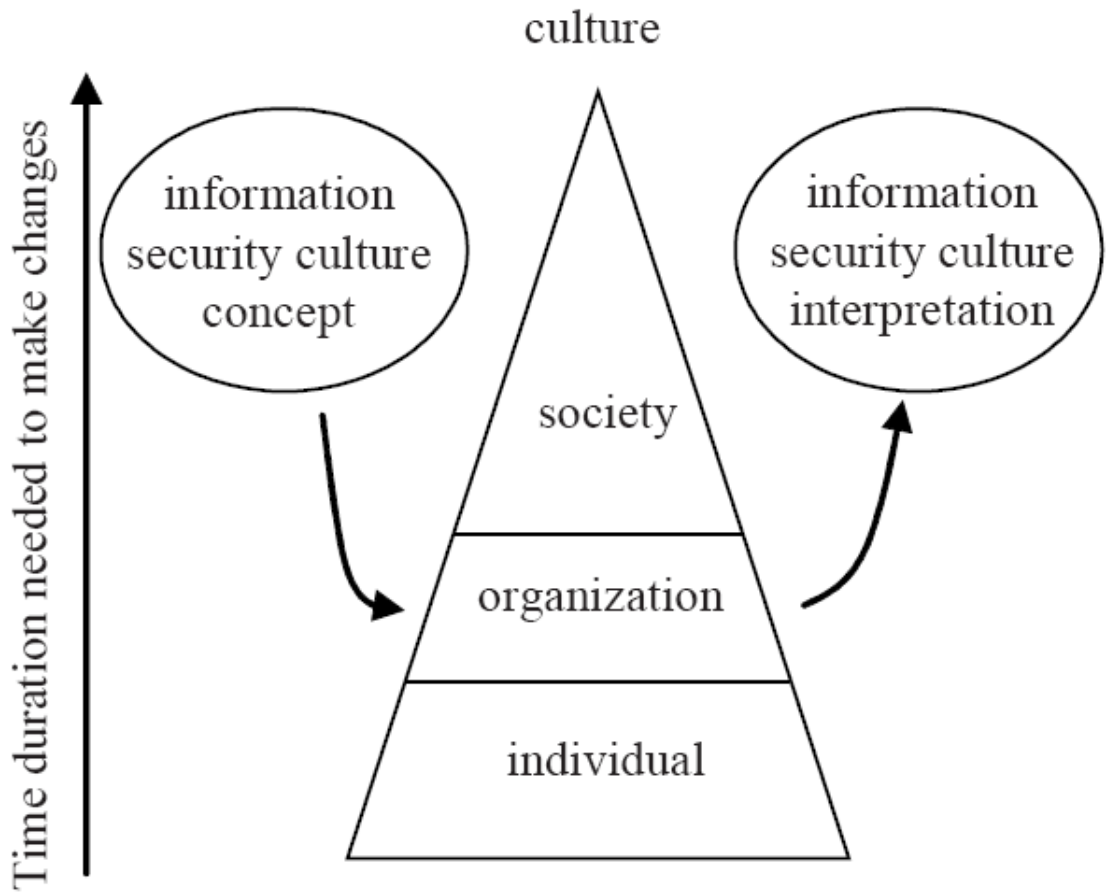
Security Perception: Individual awareness of information security

Security Acceptance: Accepts information security as an important work-habit in spite of personal inconvenience

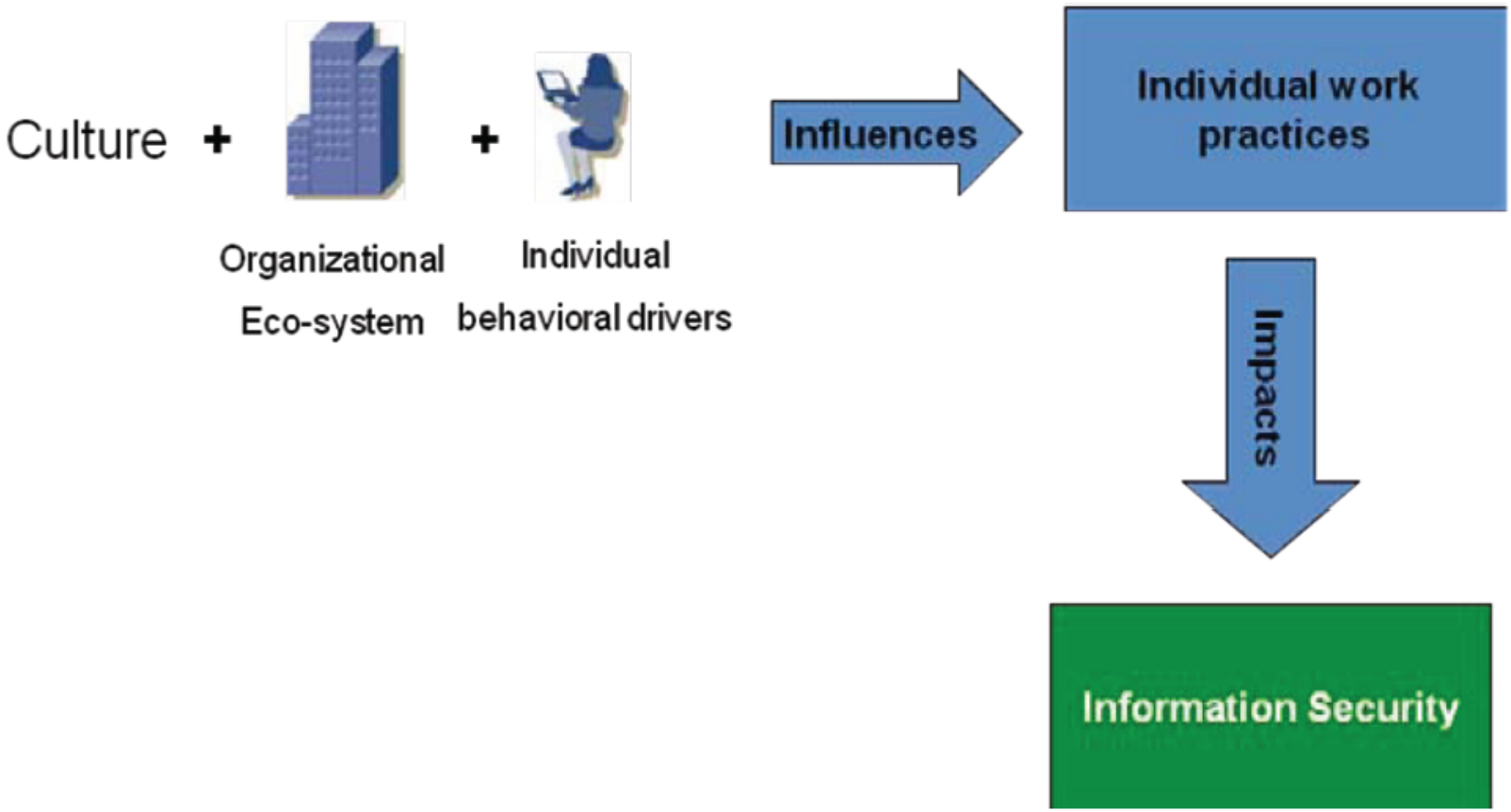
Applying Knowledge (Skills): Using security skills & ability to evaluate risks

Commitment to organization: Follows security practices and procedures

Information Security Culture



Concepts behind information security practices



UK Data Archive

- Technology
  - Firewalls
  - Penetration testing
  - Citrix technology
- Process/policy
  - ISO 27001 accreditation
  - trusted digital repositories accreditation
- Human
  - Information security training for all staff
  - Secure Data Service Training for all users

Solutions

- **Preventive measures**
  - **Education, Education, Education**
  - **Security policies**
  - **Anti-Phishing Techniques**
  - **Blacklisting**
  - **Voice Analytics**
  - **Penetration Testing**
  - **Reverse Social Engineering**
- **Monitoring measures**
  - **Auditing**
  - **Continuous measurement**
- **Corrective measures**
  - **Evaluation**

Conclusion

- Information security is ongoing management process. Make sure your people get on board and stay on board (user/staff Training).
- Insight into the interactions between people, technology and working environment requires an interdisciplinary approach involving information science, psychology and management (Holistic approach).
- Education, rather than technological solutions, appears to be the best answer to the social engineering problem. Users who are aware of attack techniques, who are trained in following safe usage policies, and who are supported by adequate technological safeguards are much more likely to recognize and deflect social engineering attacks than users who rely only on technology for protection.